Segurança de Aplicação na Nuvem

Introdução

Estudante, se você deseja segurança em sua residência, podemos dizer que mantém as portas trancadas de noite, mas você deixaria janelas sem grades abertas? Não seria muito seguro, não é mesmo? Desta forma, na computação em nuvem temos vários aspectos da segurança que devem ser observados, inclusive a própria aplicação e seu código.

Nesta aula vamos compreender melhor como a nuvem pode ser mais segura com alguns importantes cuidados com relação a construção e provisionamento da aplicação.

Objetivos da aula

- Conhecer os principais elementos da arquitetura de segurança de aplicações;
- Compreender os detalhes do ciclo de vida de desenvolvimento das aplicações para a web;
- Compreender a importância dos processos de conformidade, as principais ferramentas e serviços para aplicativos na nuvem;

- Conhecer e compreender o processo de análise de vulnerabilidades no desenvolvimento de aplicações web.

Resumo

Arquitetura de segurança de aplicações

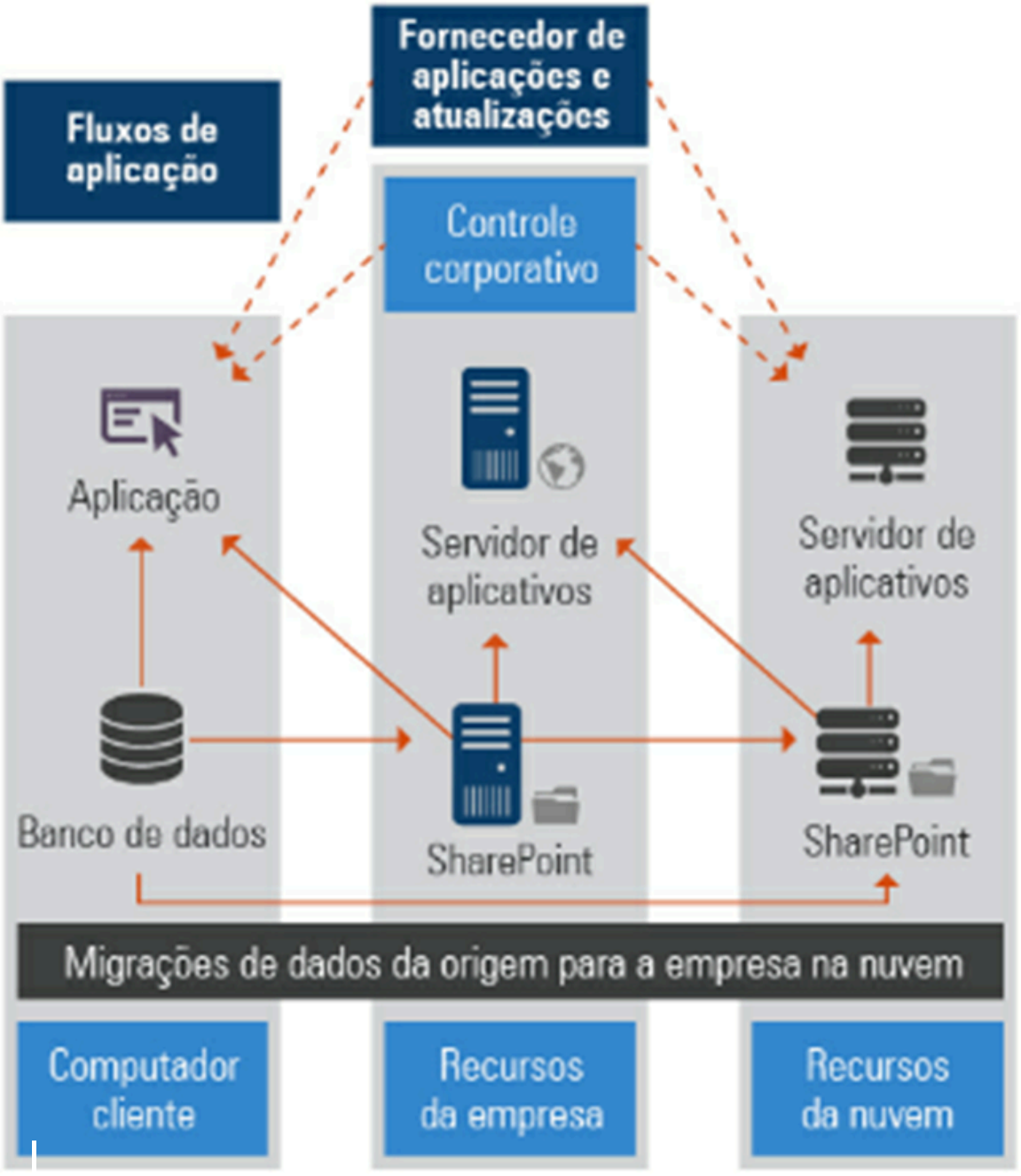
As arquiteturas de segurança de aplicativos tornaram-se complexas devido ao grande número de aplicativos criados recentemente e sua demanda crescente. Essas aplicações, principalmente a computação em nuvem, fornecem informações sobre o usuário e a empresa, e requerem atenção especial quanto aos fatores de segurança.

Para Lima (2018), os aplicativos interagem com outras soluções e se comportam como se fossem independentes de você. No entanto, sempre há usuários por trás dos aplicativos, portanto, a arquitetura precisa de segurança adicional e precisa suportar tanto a interconectividade quanto a alta demanda por esses serviços (LIMA 2018, p.89). Para usufruir dos benefícios dos serviços de computação em nuvem sem as preocupações inerentes ao ambiente web, é necessário implementar um processo de controle de acesso distribuído a conteúdos e aplicações (LIMA 2018, p.89).

Uma forma segura de se desenvolver aplicações está na escolha de modelos e paradigmas como a Arquitetura Orientada a Objetos (SOA). A equipe de desenvolvimento fornece o executável do aplicativo. Eles são implementados por fornecedores, trazendo primeiro todas as atualizações de código e aplicativo para a empresa e distribuindo-as a partir daí, proporcionando melhor controle. Conforme mostrado na Figura a seguir, os dados são migrados da máquina cliente para um

armazenamento de dados corporativo ou na nuvem apresentado como um servidor SharePoint:

Figura 1: Modelo de arquitetura da aplicação na nuvem.



Fonte: LIMA (2018, p.90).

Quando um aplicativo acessa dados, suas ações são autorizadas por mecanismos de controle de acesso locais para cada armazenamento de informações. Mantendo a integridade de aplicativos executáveis e dados

corporativos. Uma situação mais flexível é quando você pode gerenciar seus recursos locais e na nuvem como uma única entidade que po responder dinamicamente às solicitações de recursos. Os itens a seguir ajudam a se proteger na nuvem, no que tange o desenvolvimento de aplicações:

- Estabeleça uma arquitetura orientada a serviços (SOA) para garantir que possa realocar cada componente com segurança.
- Centralize o gerenciamento de implantações e atualizações de dados e aplicativos.
- Use o gerenciamento de identidades federadas para assegurar que cada usuário seja conhecido em todos os pontos da nuvem.
- Conceda funções e outros atributos a cada usuário para verificar as solicitações de acesso de dados.
- Atribua regras de controle de acesso a aplicativos e dados que possam ser movidas como eles para a nuvem.
- Autorize o acesso a aplicativos e dados com base em solicitações de acesso de usuários aprovadas. (LIMA 2018, p.92).

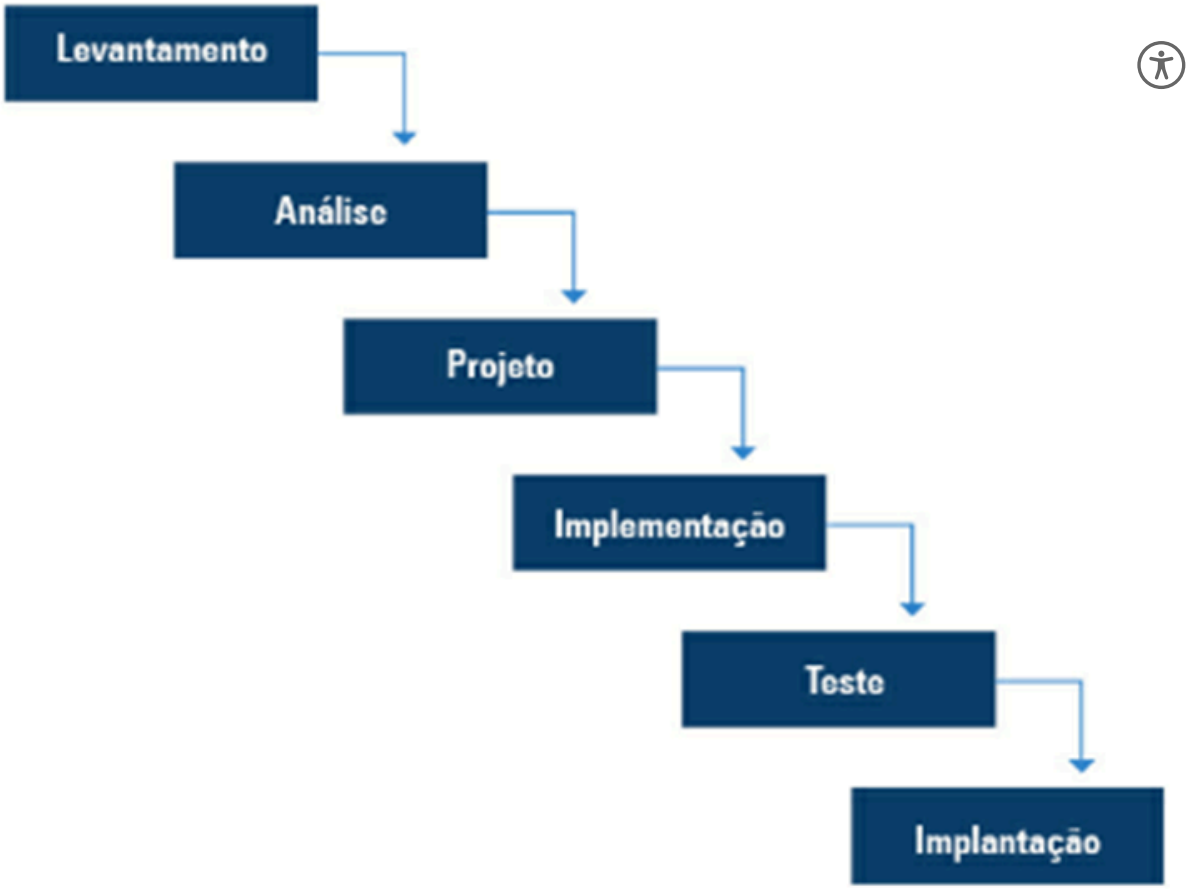
A segurança deve vir de dentro da aplicação, ou seja, de seu código, e desta forma são necessários processos, metodologias, validações, ciclos de desenvolvimento e muito mais.

Ciclo de vida de desenvolvimento

O desenvolvimento de software exige que os programadores escrevam códigos apenas para resolver problemas ou automatizar processos. Os sistemas de hoje são tão grandes e complexos que são necessárias várias equipes. Arquitetos, analistas, programadores, testadores e usuários que criam milhões de linhas de código personalizado que compõem pequenos aplicativos. São vários os métodos desenvolvidos para lidar com esse nível de complexidade, onde temos espiral, cascata, desenvolvimento ágil de software, prototipagem rápida, incremental, sincronização e estabilização.

Para Lima (2018), a mais antiga e mais conhecida forma é a cachoeira mostrada na Figura a seguir e onde podemos ver que cada saída de um processo se torna uma entrada do próximo processo.

Figura 1: Exemplo de metodologia cascata para gerenciar o ciclo de vida de um software.



Fonte: Lima (2018, p.93).

Esses modelos podem ser caracterizados e divididos de diferentes maneiras, incluindo as seguintes etapas:

- Planejamento do projeto, estudo de viabilidade: estabelece uma visão de alto nível do projeto pretendido e determina suas metas.

- Análise de sistemas e definição de requisitos: refina os objetivos do projeto em funções e projeta o funcionamento da aplicação pretendida. Analisa precisamente as informações do usuário final.

- Projeto de sistemas: descreve as características desejadas e as operações em detalhes, incluindo layouts de tela, regras de negócios, diagramas de processo, pseudocódigos e outras documentações.

- Implementação: fase em que se escreve o código para a aplicação.
  Integração e testes: caracteriza-se pela realização dos testes em ambiente apropriado, para evitar erros, bugs e interoperabilidade.

- Aceitação, instalação, implantação: consiste na fase final de desenvolvimento, na qual o software é migrado para o ambiente de produção.

- Manutenção: caracteriza-se pelo que acontece durante o ciclo de vida do software de produção: mudanças, correções, adições, etc. (LIMA 2018, p.93).

O fim do ciclo dificilmente é um momento previamente conhecido, pois as empresas buscam estender seu prazo para aproveitar melhor os recursos que foram consumidos em seu desenvolvimento. Portanto existe sempre a possibilidade do software passar pelo mesmo processo, ciclo, novamente.

Conformidades, ferramentas e serviços

Com o surgimento da computação em nuvem torna-se viável e econômico terceirizar sistemas inteiros ou processos de negócios, mantendo a conformidade com regulamentações como a política de segurança. Além disso, existem vários requisitos regulamentares e legais que uma organização deve cumprir e demonstrar aos auditores e avaliadores. Das muitas regulamentações de tecnologia da informação que as empresas devem cumprir, poucas são escritas tendo como pano de fundo as tecnologias de computação em nuvem.

Desta forma ela se adapta ao ambiente de nuvem. Os auditores e revisores podem não estar familiarizados com os requisitos especificações de um determinado serviço de nuvem e, nesse caso, se torna uma responsabilidade do cliente de computação, e assim podemos compreender que:

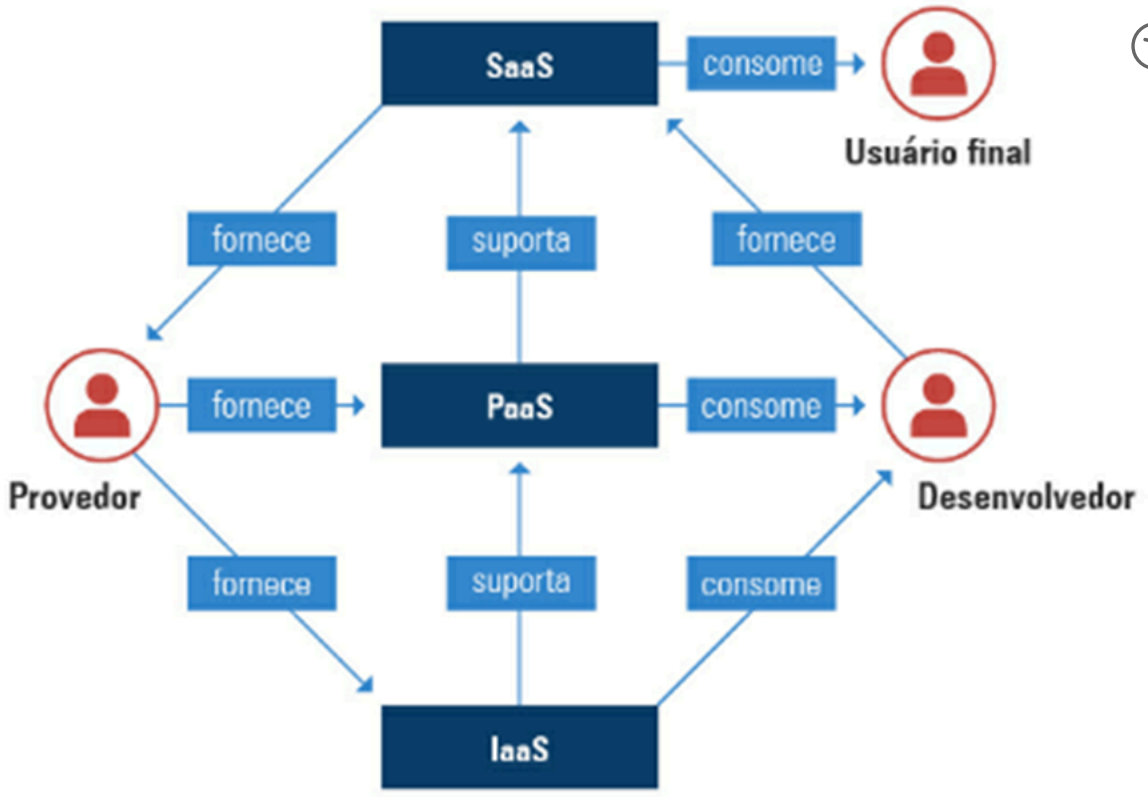
- A aplicabilidade regulatória para o uso do serviço de nuvem em questão.
- A divisão das responsabilidades pela conformidade entre o provedor do serviço e o cliente de nuvem.
- A capacidade do provedor de serviço de nuvem de produzir as evidências necessárias para a conformidade.
- Seu papel de fazer a ponte entre o provedor do serviço de nuvem e o auditor/avaliador. (LIMA 2018, p.95).

Para Lima (2018), as aplicações desenvolvidas na nuvem estão sujeitas a ataques e devem ser minuciosamente analisadas para garantir que não haja brechas de segurança. A empresa também precisa garantir que seu aplicativo seja compatível com a nuvem e suportado por serviços contratados, que muitas vezes precisam ser alterados.

Ferramentas e serviços

Para discutir as ferramentas e serviços utilizados para segurança no desenvolvimento de aplicações em computação em nuvem, precisamos ver que tipo de plataformas existem para esse tipo de tecnologia.

Figura 3: Modelos de serviços em nuvem.



Fonte: Marinos e Briscoe (2009, p.3 apud Lima 2018, p. 97).

Nas estruturas SaaS, temos que os clientes alugam os serviços prestados pelo provedor e os configuram por meio da interface do provedor sem saber qual infraestrutura é utilizada para fornecer esse serviço. Essa abordagem é chamada de SaaS porque os usuários pagam para usar o serviço de sua escolha. O Cliente não tem controle e não é responsável pelo hardware no qual os Serviços estão instalados.

Da mesma forma, de acordo com Brunetti (2011 apud Lorenzi e Grein 2022 p.05), um usuário pode controlar a operação de um sistema executando um serviço, ou controlar um software além do que um usuário apresenta em uma interface web.

Com o PaaS temos a plataforma, onde se constroem as aplicações, e no caso da infraestrutura, temos o IaaS, ou Infraestrutura como serviço, que segundo Souza (2009), o modelo Infrastructure as a Service (IaaS) é parte da computação em nuvem que permite criar sua própria infraestrutura ou simplesmente adaptá-la para atender às necessidades

de cada cliente. O objetivo é simplificar o acesso aos recursos do serviço em nuvem, como: por exemplo: Servidores, redes, armazenamento, e

Análise de vulnerabilidades

As soluções em nuvem representam uma revolução tecnológica. Embora a computação em nuvem tenha sido aclamada por sua promessa de economia de custos, muitas pessoas hesitam em usá-la porque não têm certeza sobre sua segurança. Como qualquer tecnologia, a nuvem possui algumas vulnerabilidades e muitos ataques maliciosos já existem. No entanto, empresas e profissionais familiarizados com esses desafios já estão prontos para mitigar esses riscos e habilitar soluções em nuvem para negócios de TI.

Figura 04: Visão geral da computação em nuvem.



Fonte: Orloff (2012 apud LIMA 2018, p.103).

Apesar das muitas oportunidades de economia de recursos, os líderes organizacionais relutam em mover informações, software e outros serviços para a nuvem, pois acreditam que todos os riscos associados devem ser considerados. Existem muitas vulnerabilidades que os invasores procuram explorar, e a computação em nuvem não é exceção. Mas, à medida que mais e mais profissionais de TI ficam cientes dessas vulnerabilidades, passam a aprender a controlá-los e tornar seu ambiente de nuvem mais seguro.

De acordo com Lima (2018), temos alguns dos riscos associados ao desenvolvimento de aplicativos em computação em nuvem. Antes disso, a Tabela a seguir, mostra vários modelos de implementação para computação em nuvem:

Quadro 1: Modelos de implementação da computação em nuvem.

Nuvens Públicas	Os serviços estão disponíveis na Internet e o usuário paga pelo que utiliza, aqui nasce o conceito de computação como utilidade. Nesse sentido, empresas como Microsoft, IBM e Oracle estão competindo para serem provedoras de serviços, para depois se tornarem em uma utilidade.
Nuvens Privadas	São os datacenters internos das organizações que não são disponibilizados publicamente. Desse modo, as empresas investem em técnicas como a virtualização gerando a redução de custos das operações de TI, com isso surgiu o conceito de computação em nuvem privada.
Nuvens Híbridas	Neste tipo, são compostas por duas ou mais infraestruturas de computação em nuvem, podendo ser pública, privada ou comunitária. As organizações se comportam como únicas, porém ligadas por tecnologias proprietárias ou padronizadas que ajudam a portabilidade de dados, bem como de aplicação.
Nuvens Comunitárias	Nesta situação, a infraestrutura está disponível para utilização de uma comunidade de consumidores com objetivos comuns, por exemplo: requisitos de segurança, políticas, missão, entre outros. O processo de operação e gestão podem ficar sob a responsabilidade de uma ou de mais organizações de dentro da comunidade, ou ainda, de terceiros ou de combinação desses itens (MARCO NETO, 2016). Este modelo é mais interessante para pequenas e médias empresas, visto que cada entidade contribui com sua parcela na infraestrutura geral da nuvem comunitária.

Fonte: Adaptado de Possamai et al. (2020, p.211).

Dentro do modelo de nuvem pública e modelo de nuvem comunitária a empresa tem diferentes clientes que usam a virtualização para

compartilhar recursos. Essas plataformas de computação têm alguns pontos fracos, incluindo:

- Discos compartilhados, computadores virtuais ou redes locais virtuais (VLANs);
- Drivers genéricos que emulam hardware;
- Vulnerabilidades no hypervisor, pois permitem a execução de códigos no host com os privilégios do hypervisor;
- Rootkits, baseados em máquina virtual;
- Execução de ataques de negação de serviço em uma máquina virtual. (LIMA 2018, p.106).

O primeiro passo para se proteger contra esses riscos é entender o ambiente sempre com leis, regras ou regulamentos do setor específico em que uma empresa opera, exigindo um ambiente protegido para dados ou outros recursos, e a abordagem utilizada deve respeitá-los. A solução mais recomendada nesse cenário é uma nuvem privada ou uma nuvem híbrida que hospeda dados, gateways e serviços confidenciais em um espaço privado, dando às organizações um controle mais rígido sobre segurança e acesso.

Como aplicar na prática o que aprendeu

Se você conhece algumas destas ferramentas, sua empregabilidade na nuvem está garantida!

A computação está migrando a uma grande velocidade para a nuvem para a IoT e as aplicações móveis, e para o programador existe muitas ferramentas que facilitam o ingresso neste ramo do desenvolvimento de sistemas.

Se você conhece algumas destas ferramentas, já está em um bom caminho!

Para atuar com Backend temos a Back4App, Backendless, Heroku, Firebase e DigitalOcean App Platform. Na categoria dos Frameworks é importante considerar o React Native, Flutter, Xamarin, Ionic Framework e o Cordova. Agora quando o assunto são os bancos de dados, busque mais informações sobre o Postgres, MySQL, Redis, e por fim, quando o tema é Machine Learning, busque saber mais sobre o Google ML Kit e o AWS Amplify.

Leia o artigo e veja quais são as ferramentas mais demandadas pelas empresas e que tornam você, estudante, desejado(a) para bons contratos.

Conteúdo bônus

Tópicos avançados

Conformidade e proteção de dados, o par perfeito!

Não é possível construir conformidade e compliance sem trabalhar a segurança da empresa, desta forma, o artigo indicado trabalha a combinação entre a nuvem e a conformidade, afirmando que uma é o requisito principal da outra.

Com o Compliance a empresa estabelece e torna público seu manual de procedimentos, algo vital para empresas de capital aberto. Pesqu mais sobre o tema e como você pode ser um diferencial na área que vem crescendo muito principalmente devido à maior conscientização a respeito da proteção de dados e a LGPD.

Observação: Este conteúdo não será cobrado nas avaliações e estará, obrigatoriamente, presente nas videoaulas. Fique tranquilo(a)!

Referência Bibliográfica

LIMA, Adriano Carlos de**. Segurança na computação em nuvem**. - Editora Senac São Paulo, 2018.

LORENZI, Uriel Mafra; GREIN, Willian de Brito. **Computação em Nuvem**: Conceitos, aplicações e novas tecnologias. v. 13 n. 1 (2022): Revista das Faculdades Santa Cruz. Disponível em: <http://unisantacruz.edu.br/revistas/index.php/revusc/article/view/8> Acesso em: 30 de dez, 2022.

POSSAMAI, Airan Arinê ...[...]. **Fundamentos ao cloud computing e deploy na nuvem**. – Indaial: UNIASSELVI, 2020.

Ir para questão